Physical Systems Report

Name: Mahir Singh

Contents

Task 1- Carver Matrix 3

Task 2: Attack Graph 10

Task 3- Investigation and Memos 11

Task 4- Executive Summary 38

Task 5- MITRE Attack Navigator 40

Task 1- Carver Matrix

Operational Technology Systems							
Asset	**Criticality**	**Accessibility**	**Recuperability**	**Vulnerability**	**Effect**	**Recognisability**	**Total Score**
Grit Chamber	7	10	9	8	6	9	49
Justifications	Loss reduces efficiency to 66%	Accessible from machines from Level 3 of purdue model. Logging not enabled on subnet	Siemens PLC replacement time is 6-8 weeks	Siemens S7-1200 FW v4.2 is old and outdated	Reduces operational performance	Inflow to system operated from the Engineering workstations and the HMI. First element of treatment	
Primary Clarifier	4	6	4	8	10	10	42
Justifications	If water is contaminated, primary settlement process is performed again resulting in 10% reduction in capacity of water treatment	Accessible from machines from Level 3 of purdue model. Logging not enabled on subnet. However OPS machines have limited logging enabled	Schneider has more available capacity and a lead time of only 3 days	Schneider Modicon FW v1.2 is old and outdated, Model known to have vulnerabilities that can be exploited using open source tools	10% reduction in capacity of water treatment results in reduction of income of approximately 25%, story likely to be picked up by local press	Inflow to system operated from Engineering workstations, OPS machines and the HMI. Key stage in physical process	
Secondary Clarifier	10	6	4	10	10	10	50

Justifications	If there is any risk of incorrect levels of chlorine being added to the process then there is risk to human life. Chlorine and THMs linked to cancer, kidney and liver damage, immune system dysfunction, disorders of nervous system, hardening of arteries and birth defects	Accessible from machines from Level 3 of purdue model. Logging not enabled on subnet. However OPS machines have limited logging enabled	Schneider has more available capacity and a lead time of only 3 days	Schneider Modicon FW v1.6 is old and outdated, Model known to have vulnerabilities that can be exploited using open source tools	Risk to human life, story would make international news	Inflow to system operated from Engineering workstations, SCADA server, OPS machines and the HMI. Key stage in physical process	
Sluice Gate	10	10	9	8	9	10	56

Justifications	Release of untreated water into river will contaminate river SIxe	Accessible from machines from Level 3 of purdue model. Logging not enabled on subnet	Siemens PLC replacement time is 6-8 weeks	Siemens S7-1200 FW v4.2 is old and outdated	Company can face fines from the Environment Agency if gate is opened at another time. £20.3m fine	Inflow to system operated from Engineering workstations and the HMI. Key stage in physical process	
LIMS	10	4	4	10	10	8	46
Justifications	Altered chemical compositions can cause loss of human life and can result in complete shutdown of productivity	Limited inbuilt logging, low likelihood	Backups taken every 48 hours	Ubuntu 14.1 and Open-LIMS 0.4 are very old and outdated	Loss of life, complete shutdown and significant negative publicity	Common system in water treatment laboratories	
OPS1 (Historian)	3	6	8	8	3	8	36
Justifications	Doesn't control any processes, just logs system connections and actions for forensic analysis	Contains a system logging capability	Assuming it takes the same time as FTP which is the other design server. It would take 10-14 working days	Ubuntu 18.04 is old, vsftpd 3.0.3 is very old and outdated	Minor impact as it doesn't control anything	Common SCADA component. Server uses vsftpd 3.0.3 so port scan will reveal port 21.	
HMI	8	10	4	8	8	10	48

Justifications	Direct control on all critical PLCs	Located in level 1 of Purdue model, accessible from engineering workstations, OPS and operations ws devices	Usually takes 1-3 to replace HMI	Located on level 1 of Purdue model	Loss of control can force shutdown. Service disruption noticeable to public	Located on level 1 along with other PLCs	
Engineering Workstations	8	10	4	10	8	10	50
Justifications	Control source for PLCs	Located on operations subnet where logging isn't enabled	Usually takes 1-3 to replace workstations	Running windows 7 which is old and outdated	Loss of control can force shutdown. Service disruption noticeable to public	Known as highest privilege point, operates 4 critical PLCs	
OPS Machines	6	8	4	8	6	10	42
Justifications	Controls clarifiers, loss of control would result in 1/3 reduction in outcome	Limited logging enabled by default	Usually takes 1-3 to replace machines	Running windows 7 which is old and outdated	Loss of control noticeable to public. It will also impact services	These machines are known to exist for control functions	

Enterprise Systems							
Asset	**Criticality**	**Accessibility**	**Recuperability**	**Vulnerability**	**Effect**	**Recognisability**	**Total Score**
CRM/Finance	7	4	3	8	9	9	40
Justifications	Contains financial records for both organisation and customers/suppliers. Finances cannot be managed without this	High likelihood in asset table, its on DMZ which usually has firewall and logging	Backups taken daily, offsite backups every week	Says high likelihood on asset list table. Debian 10 is old and outdated. Known vulnerabilities in Dolibarr 12.0.4	Says very high impact on asset list table, financial data is lost.	Runs Dolibarr 12.0.4. any attacker scanning DMZ will find web port.	
Web Server	7	8	2	10	8	10	45
Justifications	Public facing presence, says high impact on asset list table	Public facing presence, on DMZ making it primary target	Backups taken daily, can be used to restore within 6 hours	Says high likelihood on asset list table. Debian 10 is old and outdated. Php version is very outdated (v7.4.14)	Any downtime or defacement would negatively impact public perception	Public facing presence, server name lets attackers know compromise can affect public a lot	
UKARGO	4	8	2	10	7	9	40

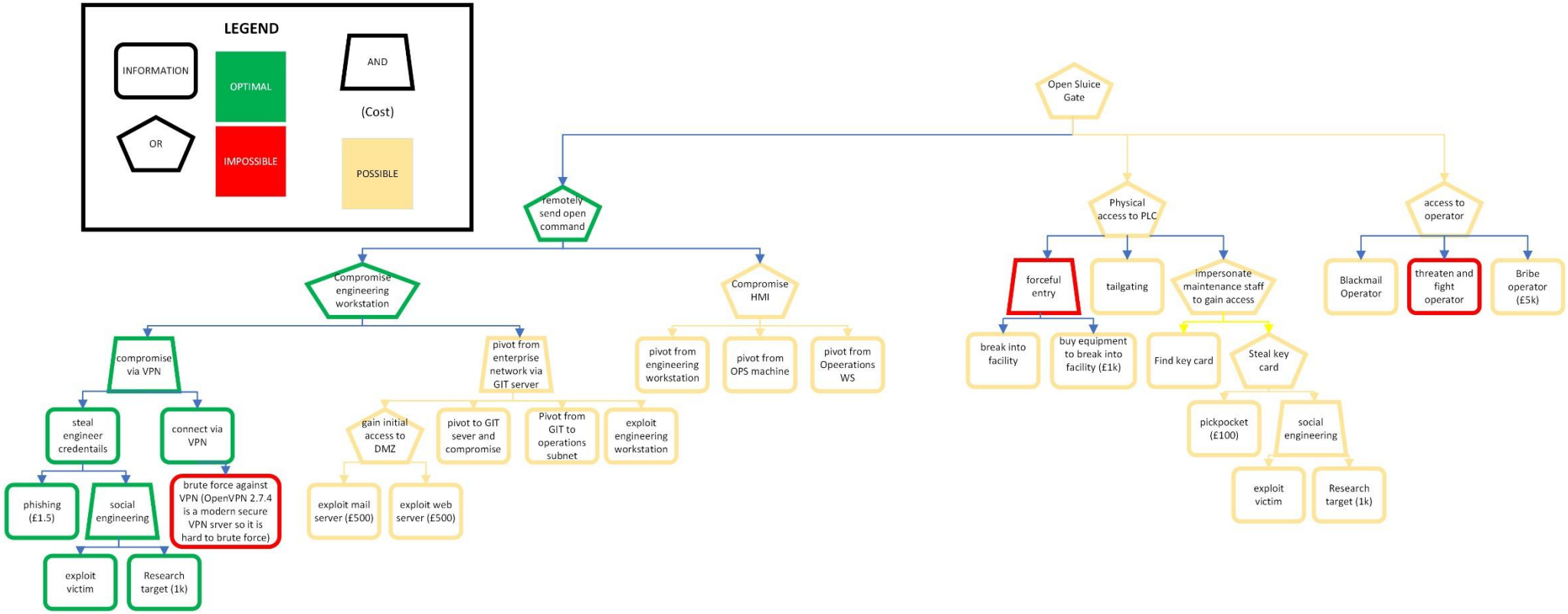
Justifications	Contains personal information falling under GDPR, says medium impact on asset list table, loss would reduce operational performance but not stop plant	Firewall access to marketing subnet, Wordpress on DMZ,	Backups taken daily	Says very high likelihood on asset list table. Debian 9 is old and outdated Wordpress 4.9.25 is vulnerable too	Beaching GDPR rules can result in fines and impact on services	Public facing, can identify it using DNS enumeration.	
FTP	8	2	7	3	8	8	36

Justifications	Contains proprietary designs, says high impact on asset list table	Deep in the network on HR subnet	Recovering lost work would take 10-14 working days	Says low likelihood on asset list table.	Loss of proprietary designs noticeable to public as it impacts services	Common service, requires limited technical expertise	
VPN	9	2	4	3	9	10	37
Justifications	Provides remote access to operations subnet to control generation process, says very high impact on asset list table	OpenVPN 2.7.4 is a modern software that requires credential theft . Low likelihood	Backup would take 36 hours from initialisation to full deployment	Says low likelihood on asset list table. Software modern and secure	Allows access to operations subnet, largescale impact	VPN server is online Public facing asset, service banner says OpenVPN 2.7.4	
DC	8	4	6	8	9	10	45

Justifications	Controls staff access to organisational resources, says very high impact on asset list table	HIDS in IT subnet where DC controller is	Backups taken weekly, retrieval doesn't take more than 1 week	Says medium likelihood on asset list table, however, its using 2012 windows server which is old	Says very high impact on asset list table, if hacked can lead to total shutdown, no access	DC is designed to be easily discoverable by all other devices so attacker just needs to ask for it using network built in functions.	
Marketing	5	7	7	7	5	9	40
Justifications	Contains customer/supplier details and business leads. Loss can reduce operational performance	Enterprise network accessible by VPN so marketing server can be accessed though that	Weekly backups taken	Says medium likelihood on asset list table. Debian 9 is old and outdated	Minor impact on current services and revenue. Losing business leads can impact future revenue	Server runs Fat Free CRM 0.18.1 which will show in port scan.	
Mail Server	7	8	2	9	7	10	43
Justifications	Essential to day-today activity. Says medium impact on asset list table	Has firewall access to IT subnet, its on DMZ	Daily backups taken, service can be restored within 5 hours	Says high likelihood on asset list table. Using Windows 7 SP1 which is very old and outdated	Loss of communication noticeable to public	Email ports will be used so easy to recognise	
GIT	8	3	9	5	5	9	39

Justifications	Information has monetary value to competitors	Low likelihood on asset list table and its on IT subnet which contains HIDS	Would take significant effort to replace	Says low likelihood on asset list table. However, Debian 9 is old and outdated and GitLab 11.9.4 is vulnerable	Says medium impact on asset list table. Loss of this data can help other competitors, affecting own business, public wont know	Has access to a lot of subnets, named GIT server so it easily recognisable requiring limited technical expertise	

Task 2: Attack Graph



I chose compromising the engineering workstation via the VPN instead of the other options because it is more affordable and is most likely to succeed. Physical access is a lot harder as forceful entry is one of the impossible nodes. This is because the risk is very high for it. Other methods deemed impossible includes threatening and fighting operators which is impossible as it would alert everyone and the attacker would get caught. Phishing is an optimal way to steal engineering credentials as it wouldn't cost much (only £2.5k). The attack tree shows that although there are several possible routes, the optimal one is compromising via VPN by stealing credentials through phishing emails and social engineering

Task 3- Investigation and Memos

INTERIM SUMMARY MEMO 1

Details

Date ……14/11/2025

Time ……15:18

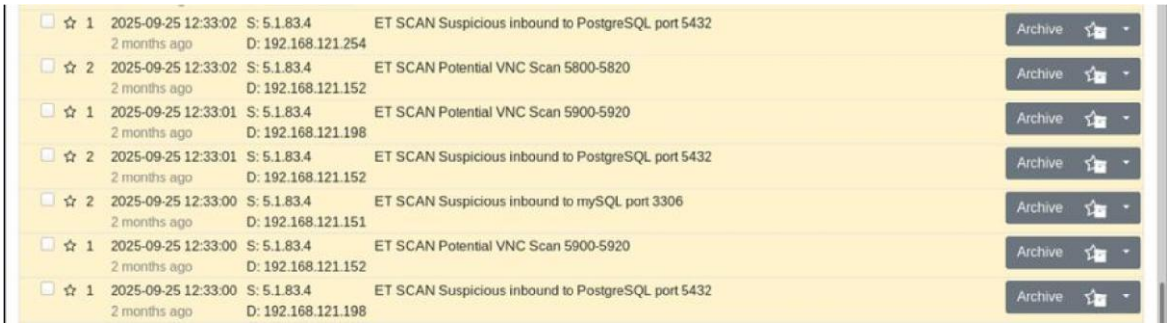
Brief description of event identified

External attacker ip 5.1.83.4 communicating with several Ips within DMZ on 25th September 2025 at 12:33. The IPs include 192.168.121.254 (VPN), 192.168.121.151 (Webserver), 192.168.121.152 (CRM/Finance), 192.168.121.198 (Mail Server)

What is the impact of this event

Attacker is scanning the DMZ to see what's the easiest entry point to the network. This initial reconnaissance lets attacker know which live hosts are present on DMZ.

Evidence (screenshot or text from file)



1	2025-09-25 12:33:02 2 months ago	S: 5.1.83.4 D: 192.168.121.254	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive
2	2025-09-25 12:33:02 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Potential VNC Scan 5800-5820	Archive
1	2025-09-25 12:33:01 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Potential VNC Scan 5900-5920	Archive
2	2025-09-25 12:33:01 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive
2	2025-09-25 12:33:00 2 months ago	S: 5.1.83.4 D: 192.168.121.151	ET SCAN Suspicious inbound to mySQL port 3306	Archive
1	2025-09-25 12:33:00 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Potential VNC Scan 5900-5920	Archive
1	2025-09-25 12:33:00 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive

INTERIM SUMMARY MEMO 2

Details

Date ……14/11/2025

Time ……15:31

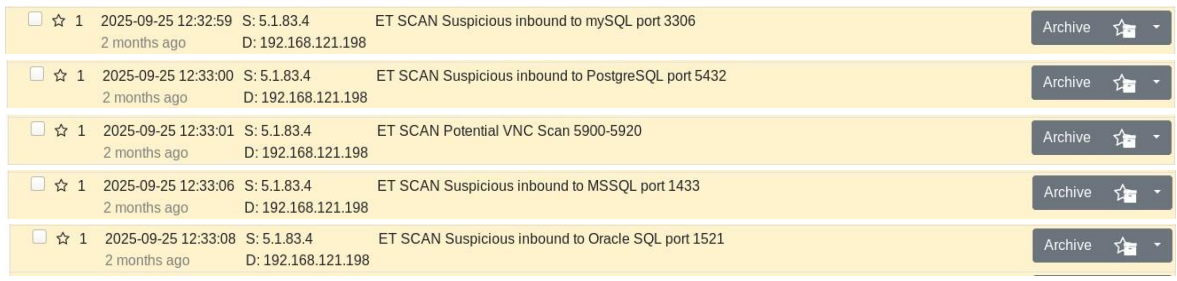
Brief description of event identified

External attacker ip 5.1.83.4 communicating carrying out specific port scans on 192.168.121.198 (Mail Server) on 25th September 2025 at 12:33. The ports that attacker attempted to scan were 3306, 5432, 5900-5920, 1433, 1521

What is the impact of this event

Attacker can find out which ports are open and accessible within the Mail server in order to try and exploit these and find more vulnerabilities. It is also scanning for any available services that can be further exploited.

Evidence (screenshot or text from file)



1	2025-09-25 12:32:59 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Suspicious inbound to mySQL port 3306	Archive
1	2025-09-25 12:33:00 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive
1	2025-09-25 12:33:01 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Potential VNC Scan 5900-5920	Archive
1	2025-09-25 12:33:06 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Suspicious inbound to MSSQL port 1433	Archive
1	2025-09-25 12:33:08 2 months ago	S: 5.1.83.4 D: 192.168.121.198	ET SCAN Suspicious inbound to Oracle SQL port 1521	Archive

INTERIM SUMMARY MEMO 3

Details

Date ……14/11/2025

Time …… 15:34

Brief description of event identified

External attacker ip 5.1.83.4 communicating carrying out specific port scans on 192.168.121.152 (CRM/Finance), on 25th September 2025 at 12:33. The ports that attacker attempted to scan were 5900-5920, 5432, 5800-5820, 1433, 1521, 3306, 22

What is the impact of this event

Attacker can find out which ports are open and accessible within the CRM/Finance server in order to try and exploit these and find more vulnerabilities. It is also scanning for any available services that can be further exploited.

Evidence (screenshot or text from file)

1	2025-09-25 12:33:00 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Potential VNC Scan 5900-5920	Archive	
2	2025-09-25 12:33:01 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive	
2	2025-09-25 12:33:02 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Potential VNC Scan 5800-5820	Archive	
1	2025-09-25 12:33:06 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Suspicious inbound to MSSQL port 1433	Archive	
16	2025-09-25 12:33:56 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN NMAP OS Detection Probe	Archive	
4	2025-09-25 12:33:36 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Suspicious inbound to Oracle SQL port 1521	Archive	
2	2025-09-25 12:34:12 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Suspicious inbound to mySQL port 3306	Archive	
3	2025-09-25 12:35:05 2 months ago	S: 5.1.83.4 D: 192.168.121.152	ET SCAN Potential SSH Scan	Archive	

INTERIM SUMMARY MEMO 4

Details

Date ……14/11/2025

Time ……15:43

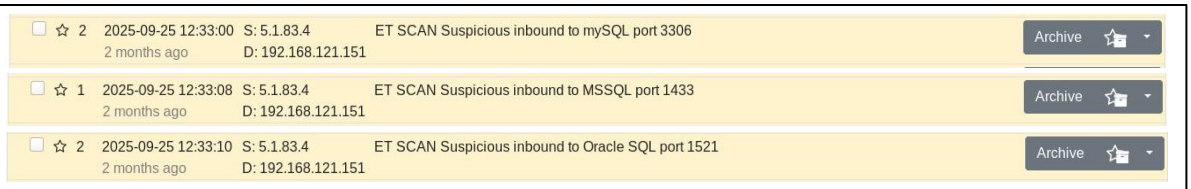
Brief description of event identified

External attacker ip 5.1.83.4 communicating carrying out specific port scans on 192.168.121.151 (Webserver), on 25th September 2025 at 12:33. The ports that attacker attempted to scan were 3306, 1433, 1521

What is the impact of this event

Attacker can find out which ports are open and accessible within the Webserver in order to try and exploit these and find more vulnerabilities. It is also scanning for any available services that can be further exploited.

Evidence (screenshot or text from file)



INTERIM SUMMARY MEMO 5

Details

Date ……14/11/2025

Time ……15:49

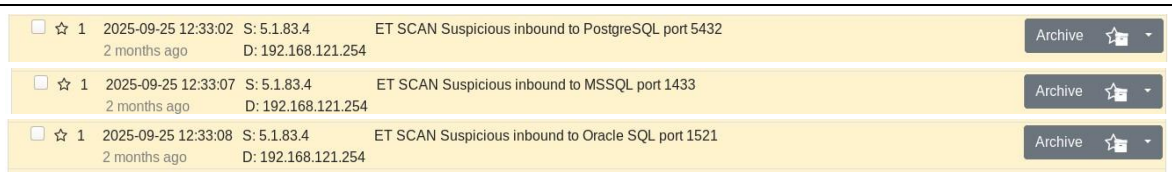
Brief description of event identified

External attacker ip 5.1.83.4 communicating carrying out specific port scans on192.168.121.254 (VPN), on 25th September 2025 at 12:33. The ports that attacker attempted to scan were 1521, 1433, 5432

What is the impact of this events

Attacker can find out which ports are open and accessible within the VPN server in order to try and exploit these and find more vulnerabilities. It is also scanning for any available services that can be further exploited.

Evidence (screenshot or text from file)



Date ……14/11/2025

Time ……17:31

Brief description of event identified

INTERIM SUMMARY MEMO 6

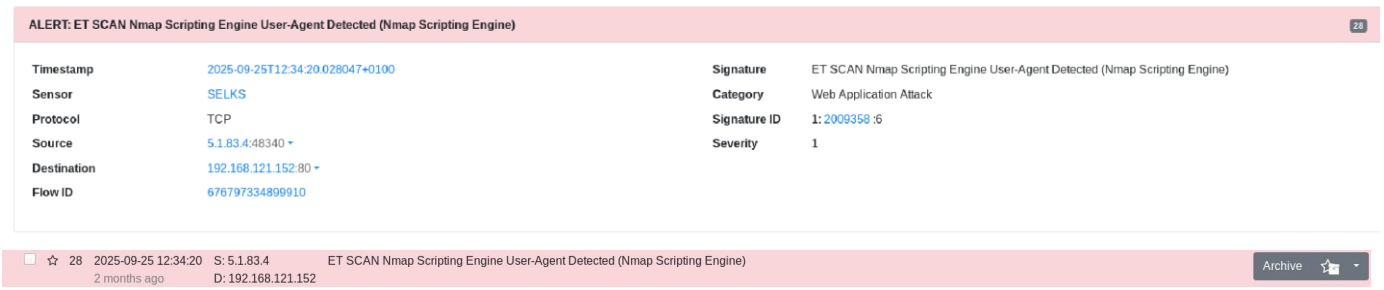
Details

External attacker ip 5.1.83.4 running an Nmap scripting engine on port 80 on 192.168.121.152 (CRM/Finance), on 25th September 2025 at 12:34

What is the impact of this event

The attacker was looking for any vulnerabilities on the server's web application (port 80) for any vulnerabilities they can exploit.

Evidence (screenshot or text from file)



ALERT: ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) 28

Timestamp	2025-09-25T12:34:20.028047+0100	Signature	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
Sensor	SELKS	Category	Web Application Attack
Protocol	TCP	Signature ID	1: 2009358 :6
Source	5.1.83.4:48340	Severity	1
Destination	192.168.121.152:80		
Flow ID	676797334899910		

28 2025-09-25 12:34:20 2 months ago S: 5.1.83.4 D: 192.168.121.152 ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) Archive

Date ……14/11/2025

Time ……18:02

Brief description of event identified

INTERIM SUMMARY MEMO 7

Details

There has been a successful brute force attempt on 25th September 2025 at 12:35 on 192.168.121.152 (CRM/Finance) after the attacker tried to log in multiple times using sshd protocol. The username that was used to log in was bitnami.

What is the impact of this event

They now have access to the server as its been compromised. Now that the attacker has access to the CRM/Finance Server they are able to use that to try and compromise other servers within the network.

Evidence (screenshot or text from file)

Sep 25, 2025 @ 12:35:27.513	067	192.168.121.152	crm	Multiple authentication failures followed by a success.

```
Sep 25 12:35:26 crm sshd[10501]: Accepted password for bitnami from 5.1.83.4 port 49526 ssh2
```

INTERIM SUMMARY MEMO 8

Details

Date ……14/11/2025

Time ……18:24

Brief description of event identified

After the attacker moved laterally from CRM/Finance Server to Finance Lead WS, they created several accounts on 25th September 2025 between 12:36 and 12-37 on 192.168.125.120 (Finance Lead WS) through sshd.

What is the impact of this event

By creating several accounts, the attacker is building backdoors to maintain access even if the original bitnami account gets disabled (persistence). This is a defense evasion technique as the attacker is making so many accounts that they won't be able to find them all and disable them.

```
Sep 25, 2025  024 @ 12:37:51.424        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-7128
        Account Name:           sshd_7128
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D2AA06
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}

Sep 25, 2025  024 @ 12:37:18.316        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-8564
        Account Name:           sshd_8564
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D27F45
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}

Sep 25, 2025  024 @ 12:37:13.991        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-10760
        Account Name:           sshd_10760
```

Evidence (screenshot or text from file)

Details

```
Sep 25, 2025 @ 12:36:54.598        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-3184
        Account Name:           sshd_3184
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D203C2
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}

Sep 25, 2025 @ 12:37:02.897        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-4316
        Account Name:           sshd_4316
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D24A96
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}

Sep 25, 2025 @ 12:36:59.109        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-5612
        Account Name:           sshd_5612
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D20F50
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}

Sep 25, 2025 @ 12:37:06.581        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-9536
        Account Name:           sshd_9536
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D25694
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}

Sep 25, 2025 @ 12:37:10.316        FinanceLead-WS      Service logon event registered from non standard service account.

New Logon:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-4720
        Account Name:           sshd_4720
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D2671B
        Linked Logon ID:                0x0
        Network Account Name:   -
        Network Account Domain: -
```


Date

……14/11/2025

Time ……18:55

Brief description of event identified

Accounts created on 192.168.125,120 (Finance Lead WS) assigned special privileges. Privilege assigned to each account named 'SeImpersonatePrivilege'. This happened shortly after the accounts were created (around 12:37) on 25th September 2025.

What is the impact of this event

The privileges assigned to the accounts suggest that it will allow the accounts to carry out processes using the identity of another user. This allows the attacker to have higher access rights on the workstation. The attacker has more control by doing this.

Evidence (screenshot or text from file)

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-3184
        Account Name:           sshd_3184
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D203C2

Privileges:             SeImpersonatePrivilege"
```

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-5612
        Account Name:           sshd_5612
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D20F50

Privileges:             SeImpersonatePrivilege"
```

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-4316
        Account Name:           sshd_4316
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D24A96

Privileges:             SeImpersonatePrivilege"
```

INTERIM SUMMARY MEMO

Details

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-4720
        Account Name:           sshd_4720
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D2671B

Privileges:             SeImpersonatePrivilege"
```

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-9536
        Account Name:           sshd_9536
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D25694

Privileges:             SeImpersonatePrivilege"
```

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-7128
        Account Name:           sshd_7128
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D2AA06

Privileges:             SeImpersonatePrivilege"
```

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-10760
        Account Name:           sshd_10760
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D2733F

Privileges:             SeImpersonatePrivilege"
```

```
"Special privileges assigned to new logon.

Subject:
        Security ID:            S-1-5-111-3847866527-469524349-687026318-516638107-1125189541-8564
        Account Name:           sshd_8564
        Account Domain:         VIRTUAL USERS
        Logon ID:               0x27D27F45

Privileges:             SeImpersonatePrivilege"
```

INTERIM SUMMARY MEMO 10

Details

Date ……15/11/2025

Time ……17:03

Brief description of event identified

The attacker has established a successful SSH connection from 192.168.121.152 to 192.168.125.120 on 25th September 2025 at 12:36

What is the impact of this event

The attacker is performing lateral movement from the DMZ to the finance network. This allows the attacker to expand control over another subnet so that they can perform further malicious acts within that new subnet that they have access to.

Evidence (screenshot or text from file)

297274	405.751692	192.168.121.152	192.168.125.120	ICMP	74	Echo (ping) reply id=0x0001, seq=2704/3687 4, ttl=62
297459	406.226272	192.168.121.152	192.168.125.120	TCP	74	40084 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=2598152695 TSecr=0 WS=128
297462	406.227455	192.168.121.152	192.168.125.120	TCP	60	40084 → 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0
297463	406.228120	192.168.121.152	192.168.125.120	SSHv2	95	Client: Protocol (SSH-2.0-OpenSSH_7.9p1 Debian-10+deb10u2)
297486	406.301523	192.168.121.152	192.168.125.120	TCP	60	40084 → 22 [ACK] Seq=42 Ack=34 Win=64256 Len=0
297487	406.302475	192.168.121.152	192.168.125.120	SSHv2	1446	Client: Key Exchange Init
297619	406.431719	192.168.121.152	192.168.125.120	SSHv2	102	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
297639	406.444817	192.168.121.152	192.168.125.120	SSHv2	70	Client: New Keys
297686	406.485557	192.168.121.152	192.168.125.120	SSHv2	98	Client: Encrypted packet (len=44)
297688	406.486587	192.168.121.152	192.168.125.120	SSHv2	130	Client: Encrypted packet (len=76)
297691	406.491561	192.168.121.152	192.168.125.120	SSHv2	434	Client: Encrypted packet (len=380)
297695	406.493112	192.168.121.152	192.168.125.120	SSHv2	154	Client: Encrypted packet (len=100)
297763	406.537051	192.168.121.152	192.168.125.120	TCP	60	40084 → 22 [ACK] Seq=2098 Ack=1806 Win=64128 Len=0

```
▾ Frame 297463: Packet, 95 bytes on wire (760 bits), 95 bytes captured (760 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:36:53.497037000 GMT Summer Time
```

INTERIM SUMMARY MEMO 11

Details

Date	……15/11/2025
Time	……17:20

Brief description of event identified

Conversations between 192.168.125.120 and several ip's within the network including inventory. 192.168.125.120 initiated unauthorised ssh connections to other internal ips including 192.168.121.152 and 192.168.170.100. the attacker successfully completed the SSH handshake with 192.168.170.100 which establishes encrypted communication on 25th September 2025 at 12:40

What is the impact of this event

This shows lateral movement within the Finance subnet and Operations subnet and DMZ. Its initiating SSH connection to the inventory which allows attacker to pivot and launch further attacks, These happened at around 12:40

INTERIM SUMMARY MEMO 12

Details

Date ……15/11/2025

Time ……17:45

Evidence (screenshot or text from file)

192.168.125.120	192.168.121.152
192.168.125.120	192.168.125.255
192.168.125.120	192.168.127.160
192.168.125.120	192.168.127.191
192.168.125.120	192.168.170.100
192.168.126.120	192.168.125.120

433701	641.734931	192.168.125.120	192.168.170.100	TCP	60	51699 → 22 [ACK] Seq=1 Ack=1 Win=2102272 Len=0
433702	641.737412	192.168.125.120	192.168.170.100	SSHv2	87	Client: Protocol (SSH-2.0-OpenSSH_for_Windows_7.7)
433705	641.760746	192.168.125.120	192.168.170.100	SSHv2	1374	Client: Key Exchange Init
433709	641.763763	192.168.125.120	192.168.170.100	SSHv2	102	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
433711	641.779924	192.168.125.120	192.168.170.100	SSHv2	70	Client: New Keys
433713	641.823064	192.168.125.120	192.168.170.100	SSHv2	98	Client: Encrypted packet (len=44)
433716	641.823566	192.168.125.120	192.168.170.100	SSHv2	122	Client: Encrypted packet (len=68)
433718	641.865048	192.168.125.120	192.168.170.100	TCP	60	51699 → 22 [ACK] Seq=1530 Ack=1868 Win=2102272 Len=0
434899	643.556912	192.168.125.120	192.168.170.100	SSHv2	138	Client: Encrypted packet (len=84)
436632	645.959937	192.168.125.120	192.168.170.100	TCP	60	51699 → 22 [ACK] Seq=1614 Ack=1920 Win=2102016 Len=0
437148	646.847410	192.168.125.120	192.168.170.100	SSHv2	138	Client: Encrypted packet (len=84)
438027	648.803779	192.168.125.120	192.168.170.100	TCP	60	51699 → 22 [ACK] Seq=1698 Ack=1972 Win=2102016 Len=0
438070	649.667945	192.168.125.120	192.168.170.100	SSHv2	138	Client: Encrypted packet (len=84)

```
▾ Frame 433702: Packet, 87 bytes on wire (696 bits), 87 bytes captured (696 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:40:49.006329000 GMT Summer Time
```

Brief description of event identified

There has been a successful brute force attempt on 25th September 2025 at 12:41 on 192.168.170.100 (Inventory) from 192.168.125.120 (Finance Lead WS) after the attacker tried to log in multiple times. The username that was used to log in was bitnami.

What is the impact of this event

This successful brute force attempt is very critical to the attack. This allows the attacker to laterally move to the inventory server which is in the Operations subnet. It allows the attacker to have initial access to the manufacturing zone. It can allow the attacker to begin targeting other assets and ips within that subnet and zone.

INTERIM SUMMARY MEMO 13

Details

Date ……15/11/2025

Time ……18:05

Evidence (screenshot or text from file)

```
Sep 25, 2025 @ 12:41:54.095   192.168.170.100   inventory   Multiple authentication failures followed by a success.

t full_log   Sep 25 12:41:53 inventory sshd[31409]: Accepted password for bitnami from 192.168.125.120 port 51707 ssh2
```

Brief description of event identified

After the attacker logged into the 192.168.170.100 (Inventory) server on 25th September 2025 at 12:41 using username bitnami, they opened a session for user root at 12:42

What is the impact of this event

This shows attacker has full root-level privilege on the inventory server. It can conduct internal reconnaissance within the operations subnet as it now has access to it with full privileges.

INTERIM SUMMARY MEMO 14

Details

Date ……15/11/2025

Time ……18:14

Evidence (screenshot or text from file)

```
Sep 25, 2025  071            inventory          PAM: Login session opened.
@
12:42:20.165


Sep 25 12:42:19 inventory sudo[31432]: pam_unix(sudo:session): session opened f
or user root by bitnami(uid=0)
```

Brief description of event identified

After opening session for root with user bitnami, the attacker executed a command using user root on 192.168.170.100 (Inventory) on 25th September 2025 at 12:42

What is the impact of this event

The command 'netstat -ano' is used for network reconnaissance to discover all active network connections and listening ports on Inventory server.

INTERIM SUMMARY MEMO 15

Details

Date ……15/11/2025

Time ……18:54

Evidence (screenshot or text from file)

```
Sep 25, 2025 @ 12:42:20.123   192.168.170.100   inventory   First time user executed sudo.

Sep 25 12:42:19 inventory sudo[31432]:  bitnami : TTY=pts/0 ; PWD=/home/bitnami ; USER=root ; COMMAND=/bin/netstat -ano
```

Brief description of event identified

Conversations between 192.168.170.100 (Inventory) and 192.168.170.111 (Engineering WS) and 192.168.170.112 (Operations WS) which are both within the manufacturing zone (Operations and ICS subnets). Inventory communicated with these on 25th September 2025 at 12:42.

What is the impact of this event

This shows internal network discovery. The attacker was trying to find out which ips the inventory can communicate with within the 2 subnets to see what next steps it could take. It was sending pings to these IPs. The attacker now knows what next asset to compromise.

INTERIM SUMMARY MEMO 16

Details

Date ……15/11/2025

Time ……19:20

Evidence (screenshot or text from file)

192.168.170.100 192.168.170.112
192.168.170.111 192.168.170.100

444601	761.312571	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=0/0, ttl=64 (reply in 444604)
444648	762.313668	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=1/256, ttl=64 (reply in 444649)
444709	763.314854	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=2/512, ttl=64 (reply in 444710)
444789	764.316004	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=3/768, ttl=64 (reply in 444790)
444834	765.317136	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=4/1024, ttl=64 (reply in 444835)

```
Frame 444601: Packet, 98 bytes on wire (784 bits), 98 bytes captured (784 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:42:48.581488000 GMT Summer Time
```

445018	768.673607	192.168.170.100	192.168.170.111	ICMP	98	Echo (ping) request id=0x7ad3, seq=0/0, ttl=64 (reply in 445021)
445058	769.674642	192.168.170.100	192.168.170.111	ICMP	98	Echo (ping) request id=0x7ad3, seq=1/256, ttl=64 (reply in 445059)
445149	770.675847	192.168.170.100	192.168.170.111	ICMP	98	Echo (ping) request id=0x7ad3, seq=2/512, ttl=64 (reply in 445150)
445216	771.677021	192.168.170.100	192.168.170.111	ICMP	98	Echo (ping) request id=0x7ad3, seq=3/768, ttl=64 (reply in 445217)
445271	772.678252	192.168.170.100	192.168.170.111	ICMP	98	Echo (ping) request id=0x7ad3, seq=4/1024, ttl=64 (reply in 445272)

```
Frame 445018: Packet, 98 bytes on wire (784 bits), 98 bytes captured (784 bits)
    Encapsulation type: Ethernet (1)
```

Brief description of event identified

Successful login recorded on GIT server through SSH public key authentication for user 'git' on 25th September 2025 at 12:43. This connection was made from 192.168.124.116.

What is the impact of this event

This is proof of the attacker trying to be stealthy and covering its tracks in a way as the attacker it establishing a backdoor on the GIT server that allows logins using their own public key. This method bypasses multiple login attempts showing up on the records and keeps a low profile so that it is difficult to detect.

INTERIM SUMMARY MEMO 17

Details

Date ……15/11/2025

Time ……19:35

Evidence (screenshot or text from file)

```
Sep 25, 2025  057          git                sshd: authentication success.
@
12:43:16.073

Sep 25 12:43:14 git sshd[1493433]: Accepted publickey for git from 192.168.124.
116 port 38344 ssh2: RSA SHA256:O2EC+VhQgInQvIPU0+HOl6Uxgdmre9lgGUvf0Co7oL4
```

Brief description of event identified

192.168.170.100 compromises 192.168.170.111 by establishing connection via Sshv2 protocol. This happens on 25th September 2025 at 12:43:54

What is the impact of this event

The attacker is able to gain control over the Engineering workstation. This allows the attacker to use that machine to perform further attacks and malicious acts.

INTERIM SUMMARY MEMO 18

Details

Date ……15/11/2025

Time ……20:40

Evidence (screenshot or text from file)

448716	827.449461	192.168.170.100	192.168.170.111	TCP	66	44508 → 22 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=44916995 TSecr=84633398
448717	827.450031	192.168.170.100	192.168.170.111	SSHv2	106	Client: Protocol (SSH-2.0-OpenSSH_7.4p1 Debian-10+deb9u6)
448744	827.501250	192.168.170.100	192.168.170.111	TCP	66	44508 → 22 [ACK] Seq=41 Ack=55 Win=29312 Len=0 TSval=44917008 TSecr=84633403
448745	827.505720	192.168.170.100	192.168.170.111	SSHv2	1498	Client: Key Exchange Init
448753	827.933291	192.168.170.100	192.168.170.111	SSHv2	114	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
448759	827.971733	192.168.170.100	192.168.170.111	SSHv2	82	Client: New Keys
448769	828.205460	192.168.170.100	192.168.170.111	SSHv2	110	Client: Encrypted packet (len=44)
448771	828.206051	192.168.170.100	192.168.170.111	SSHv2	142	Client: Encrypted packet (len=76)
448773	828.217756	192.168.170.100	192.168.170.111	SSHv2	166	Client: Encrypted packet (len=100)
448782	828.263030	192.168.170.100	192.168.170.111	TCP	66	44508 → 22 [ACK] Seq=1757 Ack=1895 Win=33280 Len=0 TSval=44917199 TSecr=84633475
448822	829.332600	192.168.170.100	192.168.170.111	SSHv2	214	Client: Encrypted packet (len=148)

```
Frame 448745: Packet, 1498 bytes on wire (11984 bits), 1498 bytes captured (11984 bits)
   Encapsulation type: Ethernet (1)
   Arrival Time: Sep 25, 2025 12:43:54.774637000 GMT Summer Time
```

Brief description of event identified

More usernames were created on the engineering workstation (192.168.170.111) on 25th September 2025 at 12:43-12:46

What is the impact of this event

Defense evasion technique as there are several users so it will be hard for staff to disable all of them. This will also confuse the staff

INTERIM SUMMARY MEMO 19

Details

Date ……15/11/2025

Time ……21:12

Evidence (screenshot or text from file)

Sep 25, 2025 @ 12:43:16.622	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	Administrator
Sep 25, 2025 @ 12:43:16.621	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	sshd_7988
Sep 25, 2025 @ 12:43:22.623	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	sshd_8212
Sep 25, 2025 @ 12:43:26.911	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	sshd_4340
Sep 25, 2025 @ 12:43:32.909	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	sshd_1208
Sep 25, 2025 @ 12:43:50.620	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	sshd_3824
Sep 25, 2025 @ 12:43:56.623	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in this system.	sshd_4656
Sep 25, 2025 @ 12:46:16.995	192.168.170.111	ENGINEERING-WS	Windows: First time this user logged in th is system.	SE-Account

Brief description of event identified

Compromised engineering workstation (192.168.170.111) is communicating with an external IP (14.136.253.55). This happens on 25th September 2025 at 12:45. I have also provided screenshots for the location of the external ip. It shows it is from Hong Kong

What is the impact of this event

This shows that the compromised workstation is establishing SSH connections with an unknown public IP which means its using it as their Command and Control channel. This can allow the attacker to send commands remotely from that IP to the workstation.

INTERIM SUMMARY MEMO 20

Details

Evidence (screenshot or text from file)

No.	Time	Source	Destination	Protocol	Length	Info
454707	934.710244	192.168.170.111	14.136.253.55	TCP	66	50780 → 22 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=4 SACK_PERM
454709	934.727948	192.168.170.111	14.136.253.55	TCP	60	50780 → 22 [ACK] Seq=1 Ack=1 Win=65700 Len=0
454715	934.734813	192.168.170.111	14.136.253.55	SSHv2	108	Client: Protocol (SSH-2.0-OpenSSH_for_Windows_9.8 Win32-OpenSSH-GitHub)
454721	934.781159	192.168.170.111	14.136.253.55	SSHv2	1486	Client: Key Exchange Init
454725	934.811792	192.168.170.111	14.136.253.55	SSHv2	102	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
454731	934.876576	192.168.170.111	14.136.253.55	SSHv2	70	Client: New Keys
454736	934.940887	192.168.170.111	14.136.253.55	SSHv2	98	Client: Encrypted packet (len=44)
454740	935.018988	192.168.170.111	14.136.253.55	SSHv2	114	Client: Encrypted packet (len=60)
454773	935.260748	192.168.170.111	14.136.253.55	TCP	60	50780 → 22 [ACK] Seq=1655 Ack=1621 Win=65604 Len=0
454920	937.634493	192.168.170.111	14.136.253.55	SSHv2	138	Client: Encrypted packet (len=84)
454930	937.685017	192.168.170.111	14.136.253.55	SSHv2	122	Client: Encrypted packet (len=68)
454931	937.686918	192.168.170.111	14.136.253.55	SSHv2	114	Client: Encrypted packet (len=60)
454935	937.755977	192.168.170.111	14.136.253.55	SSHv2	530	Client: Encrypted packet (len=476)
454949	938.001590	192.168.170.111	14.136.253.55	TCP	60	50780 → 22 [ACK] Seq=2343 Ack=2305 Win=64920 Len=0
454960	938.229547	192.168.170.111	14.136.253.55	TCP	60	50780 → 22 [ACK] Seq=2343 Ack=2741 Win=64484 Len=0

```
▾ Frame 454715: Packet, 108 bytes on wire (864 bits), 108 bytes captured (864 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:45:42.003730000 GMT Summer Time
```

INTERIM SUMMARY MEMO

Details

SSH: OpenSSH_for_Windows_9.8 -> OpenSSH_8.3p1

Timestamp	2025-09-25T12:45:42.050076+0100	**Client.Proto Version**	2.0
Sensor	SELKS	**Client.Software Version**	OpenSSH_for_Windows_9.8
Protocol	TCP	**Server.Proto Version**	2.0
Source	192.168.170.111:50780	**Server.Software Version**	OpenSSH_8.3p1
Destination	14.136.253.55:22		
Flow ID	2096056437698777		


```
  "city_name": "Central",
  "continent_code": "AS",
  "country_code2": "HK",
  "country_code3": "HK",
  "country_name": "Hong Kong",
  "ip": "14.136.253.55",
  "latitude": 22.2909,
  "location": {
    "lat": 22.2909,
    "lon": 114.15
  },
  "longitude": 114.15,
  "region_code": "HCW",
  "region_name": "Central and Western District",
  "timezone": "Asia/Hong_Kong"
},
```


Date ……15/11/2025

Time ……21:32

Brief description of event identified

After being compromised, 192.168.170.111(Engineering WS) and several ip's within the ICS subnet including PLCs and the HMI communicated. Engineering WS communicated with these on 25th September 2025 at 12:47.

What is the impact of this event

Attacker is trying to find out which Ip is live and reachable so that they can send malicious commands to them. It is trying to map out all available Ips on the ICS subnet. Finding which ones are reachable can help attacker find out their next step as they will be able to choose which plc to use to move onto the next stage of their attack

Evidence (screenshot or text from file)

192.168.170.111	192.168.174.99
192.168.170.111	192.168.174.240
192.168.170.111	192.168.174.242
192.168.170.111	192.168.174.244
192.168.170.111	192.168.174.245

459423	1012.797817	192.168.170.111	192.168.174.240	ICMP	74	Echo (ping) request id=0x0001, seq=217/55552, ttl=128 (no response found!)
459424	1012.797825	192.168.170.111	192.168.174.240	ICMP	74	Echo (ping) request id=0x0001, seq=217/55552, ttl=127 (reply in 459425)
459476	1013.794087	192.168.170.111	192.168.174.240	ICMP	74	Echo (ping) request id=0x0001, seq=218/55808, ttl=128 (no response found!)
459477	1013.794091	192.168.170.111	192.168.174.240	ICMP	74	Echo (ping) request id=0x0001, seq=218/55808, ttl=127 (reply in 459478)
459536	1014.626649	192.168.170.111	192.168.174.240	HTTP	810	POST /Scada-LTS/dwr/call/plaincall/MiscDwr.doLongPoll.dwr HTTP/1.1 (text/plain)
459539	1014.634216	192.168.170.111	192.168.174.240	TCP	60	50779 → 8080 [ACK] Seq=45361 Ack=24715 Win=65336 Len=0
459555	1014.794067	192.168.170.111	192.168.174.240	ICMP	74	Echo (ping) request id=0x0001, seq=219/56064, ttl=128 (no response found!)
459556	1014.794069	192.168.170.111	192.168.174.240	ICMP	74	Echo (ping) request id=0x0001, seq=219/56064, ttl=127 (reply in 459557)

```
Frame 459556: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:47:02.062986000 GMT Summer Time
```

460942	1032.544896	192.168.170.111	192.168.174.244	ICMP	74	Echo (ping) request id=0x0001, seq=225/57600, ttl=128 (no response found!)

```
Frame 460942: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:47:19.813813000 GMT Summer Time
```

460556	1024.445939	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=221/56576, ttl=128 (no response found!)
460557	1024.445942	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=221/56576, ttl=127 (reply in 460558)
460627	1025.450266	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=222/56832, ttl=128 (no response found!)
460628	1025.450280	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=222/56832, ttl=127 (reply in 460629)
460662	1026.450221	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=223/57088, ttl=128 (no response found!)
460663	1026.450227	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=223/57088, ttl=127 (reply in 460664)
460700	1027.450249	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=224/57344, ttl=128 (no response found!)
460701	1027.450253	192.168.170.111	192.168.174.99	ICMP	74	Echo (ping) request id=0x0001, seq=224/57344, ttl=127 (reply in 460702)

```
Frame 460556: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:47:11.714856000 GMT Summer Time
```

461758	1042.794166	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=227/58112, ttl=128 (no response found!)
461759	1042.794171	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=227/58112, ttl=127 (reply in 461760)
461804	1043.794099	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=228/58368, ttl=128 (no response found!)
461805	1043.794101	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=228/58368, ttl=127 (reply in 461806)
461879	1044.794168	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=229/58624, ttl=128 (no response found!)
461880	1044.794175	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=229/58624, ttl=127 (reply in 461881)
461961	1045.793893	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=230/58880, ttl=128 (no response found!)
461962	1045.793895	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=230/58880, ttl=127 (reply in 461964)

```
Frame 461758: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: Sep 25, 2025 12:47:30.063083000 GMT Summer Time
```

INTERIM SUMMARY MEMO 21

Details

Date ……15/11/2025

Time ……21:47

Brief description of event identified

192.168.170.111 compromises 192.168.174.245 (PLC) to modify value of holding register 10 which prevented SCADA system from registering the dangerously high flow ratee of 55L per second. This occurs on 25th September 2025 at 12:49.

What is the impact of this event

The attacker doing this allowed the plant to not get notified about the high level of chlorine. It suppressed the critical safety alarm which led to emergency physical shutdown of the plant.

INTERIM SUMMARY MEMO 22

Details

Evidence (screenshot or text from file)

modbus && modbus.regval_uint16 <= 10

No.	Time	Source	Destination	Protocol	Length	Info
466236	1134.389029	192.168.174.245	192.168.170.111	Modbus…	85	Response: Trans: 2; Unit: 1, Func: 3: Read Holding Registers
466279	1135.388417	192.168.174.245	192.168.170.111	Modbus…	85	Response: Trans: 3; Unit: 1, Func: 3: Read Holding Registers
466717	1144.123833	192.168.174.245	192.168.174.240	Modbus…	65	Response: Trans: 24; Unit: 1, Func: 3: Read Holding Registers
467042	1150.545816	192.168.174.245	192.168.170.111	Modbus…	85	Response: Trans: 1; Unit: 1, Func: 3: Read Holding Registers
467078	1151.545132	192.168.174.245	192.168.170.111	Modbus…	85	Response: Trans: 2; Unit: 1, Func: 3: Read Holding Registers
467095	1151.653611	192.168.174.245	192.168.174.240	Modbus…	85	Response: Trans: 2792; Unit: 1, Func: 3: Read Holding Registers
467171	1152.545389	192.168.174.245	192.168.170.111	Modbus…	85	Response: Trans: 3; Unit: 1, Func: 3: Read Holding Registers
467305	1154.125526	192.168.174.245	192.168.174.240	Modbus…	65	Response: Trans: 28; Unit: 1, Func: 3: Read Holding Registers
467642	1160.239061	192.168.170.111	192.168.174.245	Modbus…	69	Query: Trans: 1; Unit: 1, Func: 16: Write Multiple Registers

```
Modbus
    0... .... = Exception: No
    .001 0000 = Function Code: Write Multiple Registers (16)
    Reference Number: 10
    Word Count: 1
    Byte Count: 2
  ▸ Register 10 (UINT16): 5
```

```
Frame 467642: Packet, 69 bytes on wire (552 bits), 69 bytes captured (552 bits)
  Encapsulation type: Ethernet (1)
  Arrival Time: Sep 25, 2025 12:49:27.507978000 GMT Summer Time
```

Date ……15/11/2025

Time ……22:12

Brief description of event identified

After the attack occurred at 12:50 where the holding register 10 was changed, the attacker cleared the Microsoft Event logs and the Windows audit logs.

What is the impact of this event

INTERIM SUMMARY MEMO 23

Details

This allows the attacker to cover its tracks as the logs would've shown what the attacker was doing throughout the attack. It will make it harder for the staff to find out and pinpoint the attacker.

Evidence (screenshot or text from file)

Sep 25, 2025 @ 12:50:06.792	192.168.170.11 1	ENGINEERING-WS	Windows audit log was cle ared.	2025 Sep 25 12:50:03 WinEvtLog: Security: AUDIT_SUCCESS(1102): Microsoft -Windows-Eventlog: (no user): no domain: ENGINEERING-WS.CTiUtilities.co m: S-1-5-21-3624147821-3761609462-1504334138-500 Administrator ENGINEERI NG-WS 0x141c6031
Sep 25, 2025 @ 12:50:06.792	192.168.170.11 1	ENGINEERING-WS	Windows audit log was cle ared.	2025 Sep 25 12:50:03 WinEvtLog: Security: AUDIT_SUCCESS(1102): Microsoft -Windows-Eventlog: (no user): no domain: ENGINEERING-WS.CTiUtilities.co m: S-1-5-21-3624147821-3761609462-1504334138-500 Administrator ENGINEERI NG-WS 0x141c6031
Sep 25, 2025 @ 12:50:04.613	192.168.170.11 1	ENGINEERING-WS	Microsoft Event log clear ed.	ossec: Event log cleared: 'Security'
Sep 25, 2025 @ 12:50:04.613	192.168.170.11 1	ENGINEERING-WS	Microsoft Event log clear ed.	ossec: Event log cleared: 'Security'

Date ……15/11/2025

Time ……22:28

Brief description of event identified

Unusual protocols that were used throughout the attack. These were SSHv2 and ICMP

What is the impact of this event

ICMP protocol is used by the attacker to send pings to discover live hosts and potential Ips that can be used to take over. SSHv2 protocol was used by the attacker to establish

INTERIM SUMMARY MEMO 24

Details

connections to several Ips n different subnets so that the attacker can perform lateral movement.

Evidence (screenshot or text from file)

448716	827.449461	192.168.170.100	192.168.170.111	TCP	66	44508 → 22 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=44916995 TSecr=84633398
448717	827.450031	192.168.170.100	192.168.170.111	SSHv2	106	Client: Protocol (SSH-2.0-OpenSSH_7.4p1 Debian-10+deb9u6)
448744	827.501250	192.168.170.100	192.168.170.111	TCP	66	44508 → 22 [ACK] Seq=41 Ack=55 Win=29312 Len=0 TSval=44917008 TSecr=84633403
448745	827.505720	192.168.170.100	192.168.170.111	SSHv2	1498	Client: Key Exchange Init
448753	827.933291	192.168.170.100	192.168.170.111	SSHv2	114	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
448759	827.971733	192.168.170.100	192.168.170.111	SSHv2	82	Client: New Keys
448769	828.205460	192.168.170.100	192.168.170.111	SSHv2	110	Client: Encrypted packet (len=44)
448771	828.206051	192.168.170.100	192.168.170.111	SSHv2	142	Client: Encrypted packet (len=76)
448773	828.217756	192.168.170.100	192.168.170.111	SSHv2	166	Client: Encrypted packet (len=100)
448782	828.263030	192.168.170.100	192.168.170.111	TCP	66	44508 → 22 [ACK] Seq=1757 Ack=1895 Win=33280 Len=0 TSval=44917199 TSecr=84633475
448822	829.332600	192.168.170.100	192.168.170.111	SSHv2	214	Client: Encrypted packet (len=148)

444601	761.312571	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=0/0, ttl=64 (reply in 444604)
444648	762.313668	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=1/256, ttl=64 (reply in 444649)
444709	763.314854	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=2/512, ttl=64 (reply in 444710)
444789	764.316004	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=3/768, ttl=64 (reply in 444790)
444834	765.317136	192.168.170.100	192.168.170.112	ICMP	98	Echo (ping) request id=0x7acf, seq=4/1024, ttl=64 (reply in 444835)

461758	1042.794166	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=227/58112, ttl=128 (no response found!)
461759	1042.794171	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=227/58112, ttl=127 (reply in 461760)
461804	1043.794099	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=228/58368, ttl=128 (no response found!)
461805	1043.794101	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=228/58368, ttl=127 (reply in 461806)
461879	1044.794168	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=229/58624, ttl=128 (no response found!)
461880	1044.794175	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=229/58624, ttl=127 (reply in 461881)
461961	1045.793893	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=230/58880, ttl=128 (no response found!)
461962	1045.793895	192.168.170.111	192.168.174.245	ICMP	74	Echo (ping) request id=0x0001, seq=230/58880, ttl=127 (reply in 461964)

433701	641.734931	192.168.125.120	192.168.170.100	TCP	60	51699 → 22 [ACK] Seq=1 Ack=1 Win=2102272 Len=0
433702	641.737412	192.168.125.120	192.168.170.100	SSHv2	87	Client: Protocol (SSH-2.0-OpenSSH_for_Windows_7.7)
433705	641.760746	192.168.125.120	192.168.170.100	SSHv2	1374	Client: Key Exchange Init
433709	641.763763	192.168.125.120	192.168.170.100	SSHv2	102	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
433711	641.779924	192.168.125.120	192.168.170.100	SSHv2	70	Client: New Keys
433713	641.823064	192.168.125.120	192.168.170.100	SSHv2	98	Client: Encrypted packet (len=44)
433716	641.823566	192.168.125.120	192.168.170.100	SSHv2	122	Client: Encrypted packet (len=68)
433718	641.865048	192.168.125.120	192.168.170.100	TCP	60	51699 → 22 [ACK] Seq=1530 Ack=1868 Win=2102272 Len=0
434899	643.556912	192.168.125.120	192.168.170.100	SSHv2	138	Client: Encrypted packet (len=84)

Task 4- Executive Summary

Findings

The attacker started the attack on the DMZ, moved to the Enterprise assets and worked their way into the Operational assets like the industrial control systems to cause physical damage.

The attack began at 12:33 pm when the attacker started researching our public-facing servers in the DMZ. By 12:35 pm, they had successfully broken into our CRM/Finance server by forcefully getting logging into an account with the username 'bitnami' using a technique called Brute Force attack which works when passwords are weak and guessable.

After they were inside the CRM/Finance server, the attacker continued moving across subnets. At 12:36 pm, they used the compromised CRM server to move to a workstation in the Finance subnet called Finance Lead WS. On this machine, they created several accounts to ensure they could get back in later and keep control.

After getting into the finance network and keeping control, at 12:41 pm, the attacker moved into the Operations network, breaking into the Inventory server. They once again forcefully logged into an account with the username 'bitnami' to get access to the Inventory server. They gave themselves full administrator privileges by getting into a username called root which usually has all the rights to do anything on the machine. The attacker then began looking for their next target.

At 12:43 pm, they compromised the Engineering Workstation. This machine was located in the Operations subnet which is where the Inventory was. From there, they made an outbound connection to an unknown address in Hong Kong to maybe receive further instructions or to just keep control.

Taking over the Engineering Workstation led to the final attack. At 12:49 pm, the attacker used the compromised Engineering Workstation to send malicious commands directly to the Secondary Clarifier's. This allowed the dangerously high chlorine levels to go undetected which forced the emergency physical shutdown at the plant. After they caused the physical shutdown, the attacker deleted the system logs to try cover their tracks at 12:50 pm.

Security recommendations with business impacts of each change

My first recommendation is to introduce a new strong password policy. The attacker easily brute forced their way to several machines throughout the attack. They were able to get into the Finance and the plant's Inventory server. The password policy should make the passwords set less guessable. There isn't much business impact as it doesn't cost to implement new password rules.
My second recommendation is to add network segmentation and a "least privilege" model. This is because the attacker moved freely from multiple subnets. Blocking all traffic between different subnets and creating secure, monitored conduits for essential traffic will fix the

problem. The business impact is maintanance. It will require downtime to reconfigure the network. The plant will have to stop which is very unlikely as it runs 24/7.

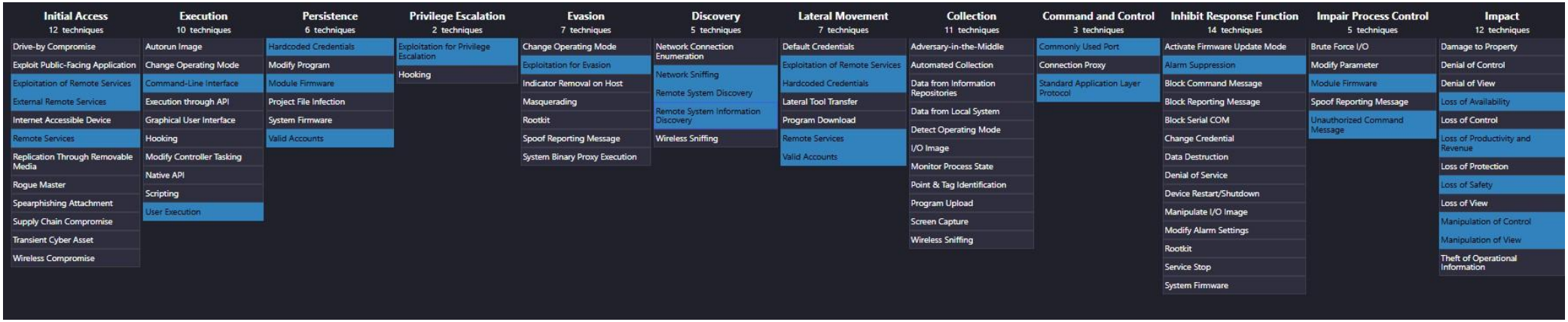
My third recommendation is reconfiguring the firewall. This is because the compromised Engineering Workstation established a command-and-control channel to an external IP. configuring the firewall to block all outbound traffic by default will fix the issue. Allowlists and blocklists could also be introduced. This could cost the business as configuring firewalls is done by specialists. It doesn't have an impact on normal plant operations.

My fourth recommendation is to implement Physics-Based Attack Detection system. This is because the attacker changed the SCADA data, changing a 55L chlorine level. This is a physical-law anomaly. A physics-based detection system can compare the chlorine levels with the fact that it would've been impossible for the chlorine level to be what it was at 12:50. This will trigger an alarm. The business impact is that it will cost a lot as a new detection software will be bought. However it provides safety that cannot be bypassed with data manipulation.

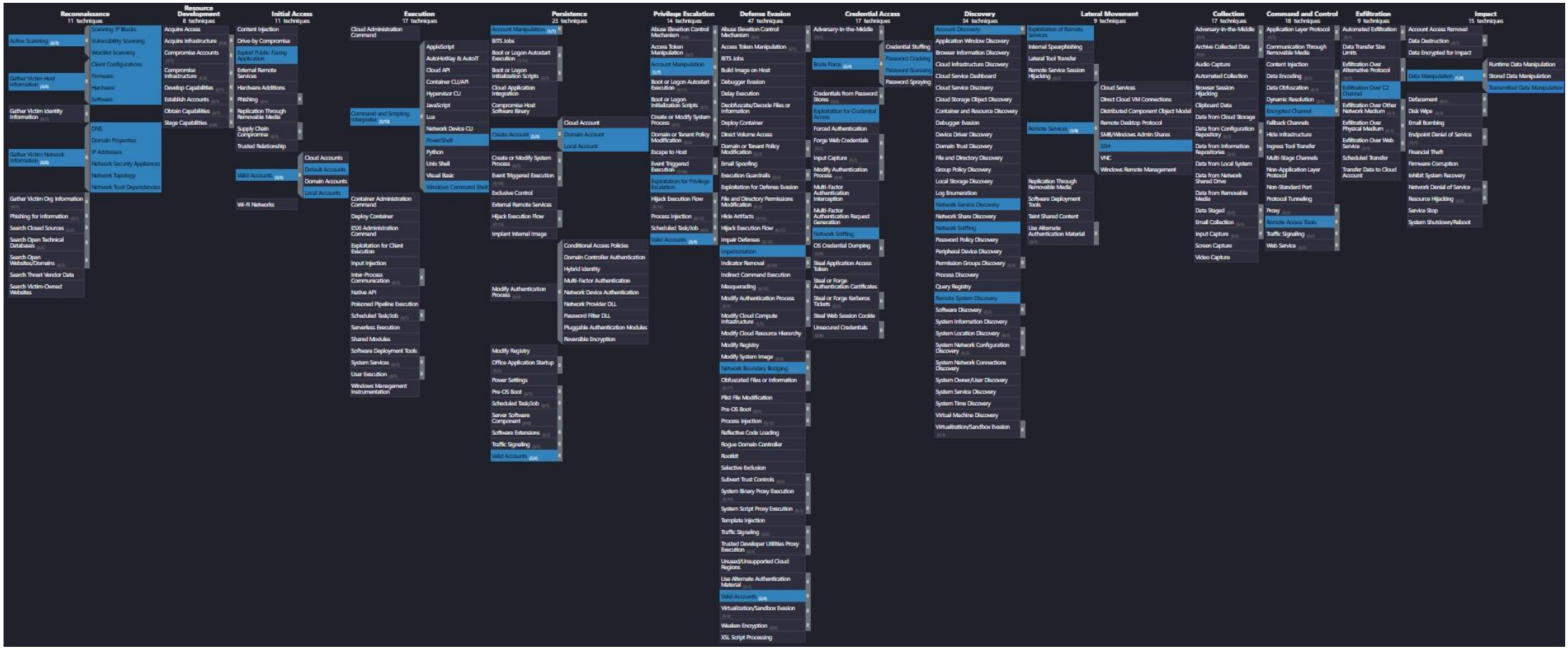
My fifth recommendation is to Replace the systems with upgraded ones. This is because the plant relies on vulnerable, end-of-life systems. These are are easy targets. The business impact for this recommendation is that it will be very costly and almost impossible to carry out. These PLCs and systems usually run 24/7 which means upgrading or patching them will require downtime and a lot of maintenance which means stopping the water treatment process. Services may be unavailable for some time which will reduce operational performance. However, failing to address these vulnerabilities can leave the plant exposed to future attacks that may be even more damaging.

Task 5- MITRE Attack Navigator

ICS



Enterprise


Reconnaissance
11 techniques
Active Scanning (0/3)
Scanning IP Blocks
Vulnerability Scanning
Wordlist Scanning
Gather Victim Host Information (0/4)
Client Configurations
Firmware
Hardware
Software
Gather Victim Identity Information (0/3)
DNS
Domain Properties
Gather Victim Network Information (0/6)
IP Addresses
Network Security Appliances
Network Topology
Network Trust Dependencies
Gather Victim Org Information (0/4)
Phishing for Information (0/3)
Search Closed Sources (0/2)
Search Open Technical Databases (0/5)
Search Open Websites/Domains (0/3)
Search Threat Vendor Data
Search Victim-Owned Websites
Resource Development
8 techniques
Acquire Access
Acquire Infrastructure (0/8)
Compromise Accounts (0/3)
Compromise Infrastructure (0/6)
Develop Capabilities (0/4)
Establish Accounts (0/3)
Obtain Capabilities (0/7)
Stage Capabilities (0/6)
Initial Access
11 techniques
Content Injection
Drive-by Compromise
Exploit Public-Facing Application
External Remote Services
Hardware Additions
Phishing (0/3)
Replication Through Removable Media
Supply Chain Compromise (0/3)
Trusted Relationship
Valid Accounts (0/4)
Cloud Accounts
Default Accounts
Domain Accounts
Local Accounts
Wi-Fi Networks
Execution
17 techniques
Cloud Administration Command
Command and Scripting Interpreter (0/10)
AppleScript
AutoHotKey & AutoIT
Cloud API
Container CLI/API
Hypervisor CLI
JavaScript
Lua
Network Device CLI
PowerShell
Python
Unix Shell
Visual Basic
Windows Command Shell
Container Administration Command
Deploy Container
ESXi Administration Command
Exploitation for Client Execution
Input Injection
Inter-Process Communication (0/3)
Native API
Poisoned Pipeline Execution
Scheduled Task/Job (0/5)
Serverless Execution
Shared Modules
Software Deployment Tools
System Services (0/2)
User Execution (0/3)
Windows Management Instrumentation
Persistence
23 techniques
Account Manipulation (0/7)
BITS Jobs
Boot or Logon Autostart Execution (0/14)
Boot or Logon Initialization Scripts (0/5)
Cloud Application Integration
Compromise Host Software Binary
Create Account (0/3)
Cloud Account
Domain Account
Local Account
Create or Modify System Process (0/5)
Event Triggered Execution (0/16)
Exclusive Control
External Remote Services
Hijack Execution Flow (0/12)
Implant Internal Image
Modify Authentication Process (0/9)
Conditional Access Policies
Domain Controller Authentication
Hybrid Identity
Multi-Factor Authentication
Network Device Authentication
Network Provider DLL
Password Filter DLL
Pluggable Authentication Modules
Reversible Encryption
Modify Registry
Office Application Startup (0/6)
Power Settings
Pre-OS Boot (0/5)
Scheduled Task/Job (0/5)
Server Software Component (0/5)
Software Extensions (0/2)
Traffic Signaling (0/2)
Valid Accounts (0/4)
Privilege Escalation
14 techniques
Abuse Elevation Control Mechanism (0/6)
Access Token Manipulation (0/5)
Account Manipulation (0/7)
Boot or Logon Autostart Execution (0/14)
Boot or Logon Initialization Scripts (0/5)
Create or Modify System Process (0/5)
Domain or Tenant Policy Modification (0/2)
Escape to Host
Event Triggered Execution (0/16)
Exploitation for Privilege Escalation
Hijack Execution Flow (0/12)
Process Injection (0/12)
Scheduled Task/Job (0/5)
Valid Accounts (0/4)
Defense Evasion
47 techniques
Abuse Elevation Control Mechanism (0/6)
Access Token Manipulation (0/5)
BITS Jobs
Build Image on Host
Debugger Evasion
Delay Execution
Deobfuscate/Decode Files or Information
Deploy Container
Direct Volume Access
Domain or Tenant Policy Modification (0/2)
Email Spoofing
Execution Guardrails (0/2)
Exploitation for Defense Evasion
File and Directory Permissions Modification (0/2)
Hide Artifacts (0/10)
Hijack Execution Flow (0/12)
Impair Defenses (0/10)
Impersonation
Indicator Removal (0/10)
Indirect Command Execution
Masquerading (0/10)
Modify Authentication Process (0/9)
Modify Cloud Compute Infrastructure (0/7)
Modify Cloud Resource Hierarchy
Modify Registry
Modify System Image (0/2)
Network Boundary Bridging
Obfuscated Files or Information (0/17)
Plist File Modification
Pre-OS Boot (0/5)
Process Injection (0/12)
Reflective Code Loading
Rogue Domain Controller
Rootkit
Selective Exclusion
Subvert Trust Controls (0/6)
System Binary Proxy Execution (0/13)
System Script Proxy Execution (0/4)
Template Injection
Traffic Signaling (0/2)
Trusted Developer Utilities Proxy Execution
Unused/Unsupported Cloud Regions
Use Alternate Authentication Material (0/4)
Valid Accounts (0/4)
Virtualization/Sandbox Evasion (0/3)
Weaken Encryption (0/2)
XSL Script Processing
Credential Access
17 techniques
Adversary-in-the-Middle (0/3)
Brute Force (0/4)
Credential Stuffing
Password Cracking
Password Guessing
Password Spraying
Credentials from Password Stores (0/5)
Exploitation for Credential Access
Forced Authentication
Forge Web Credentials (0/2)
Input Capture (0/4)
Modify Authentication Process (0/9)
Multi-Factor Authentication Interception
Multi-Factor Authentication Request Generation
Network Sniffing
OS Credential Dumping (0/8)
Steal Application Access Token
Steal or Forge Authentication Certificates
Steal or Forge Kerberos Tickets (0/5)
Steal Web Session Cookie
Unsecured Credentials (0/8)
Discovery
34 techniques
Account Discovery (0/4)
Application Window Discovery
Browser Information Discovery
Cloud Infrastructure Discovery
Cloud Service Dashboard
Cloud Service Discovery
Cloud Storage Object Discovery
Container and Resource Discovery
Debugger Evasion
Device Driver Discovery
Domain Trust Discovery
File and Directory Discovery
Group Policy Discovery
Local Storage Discovery
Log Enumeration
Network Service Discovery
Network Share Discovery
Network Sniffing
Password Policy Discovery
Peripheral Device Discovery
Permission Groups Discovery (0/3)
Process Discovery
Query Registry
Remote System Discovery
Software Discovery (0/1)
System Information Discovery
System Location Discovery (0/3)
System Network Configuration Discovery (0/2)
System Network Connections Discovery
System Owner/User Discovery
System Service Discovery
System Time Discovery
Virtual Machine Discovery
Virtualization/Sandbox Evasion (0/3)
Lateral Movement
9 techniques
Exploitation of Remote Services
Internal Spearphishing
Lateral Tool Transfer
Remote Service Session Hijacking (0/2)
Remote Services (1/6)
Cloud Services
Direct Cloud VM Connections
Distributed Component Object Model
Remote Desktop Protocol
SMB/Windows Admin Shares
SSH
VNC
Windows Remote Management
Replication Through Removable Media
Software Deployment Tools
Taint Shared Content
Use Alternate Authentication Material (0/4)
Collection
17 techniques
Adversary-in-the-Middle (0/3)
Archive Collected Data (0/3)
Audio Capture
Automated Collection
Browser Session Hijacking
Clipboard Data
Data from Cloud Storage
Data from Configuration Repository (0/2)
Data from Information Repositories (0/3)
Data from Local System
Data from Network Shared Drive
Data from Removable Media
Data Staged (0/2)
Email Collection (0/3)
Input Capture (0/4)
Screen Capture
Video Capture
Command and Control
18 techniques
Application Layer Protocol (0/5)
Communication Through Removable Media
Content Injection
Data Encoding (0/2)
Data Obfuscation (0/3)
Dynamic Resolution (0/3)
Encrypted Channel (0/2)
Fallback Channels
Hide Infrastructure
Ingress Tool Transfer
Multi-Stage Channels
Non-Application Layer Protocol
Non-Standard Port
Protocol Tunneling
Proxy (0/4)
Remote Access Tools (0/3)
Traffic Signaling (0/2)
Web Service (0/3)
Exfiltration
9 techniques
Automated Exfiltration (0/1)
Data Transfer Size Limits
Exfiltration Over Alternative Protocol (0/3)
Exfiltration Over C2 Channel
Exfiltration Over Other Network Medium (0/1)
Exfiltration Over Physical Medium (0/1)
Exfiltration Over Web Service (0/3)
Scheduled Transfer
Transfer Data to Cloud Account
Impact
15 techniques
Account Access Removal
Data Destruction (0/3)
Data Encrypted for Impact
Data Manipulation (1/3)
Runtime Data Manipulation
Stored Data Manipulation
Transmitted Data Manipulation
Defacement (0/2)
Disk Wipe (0/2)
Email Bombing
Endpoint Denial of Service (0/4)
Financial Theft
Firmware Corruption
Inhibit System Recovery
Network Denial of Service (0/2)
Resource Hijacking (0/2)
Service Stop
System Shutdown/Reboot